

Name: Abraham Abebe

Course: Cybersecurity

Date: July 29, 2026

Title: Social Engineering Toolkit (SET) and
Reconnaissance Lab

Exercise 1: Creating Phishing Pages with the Social Engineering Toolkit (SET)

Objective

The objective of this exercise was to demonstrate how the Social Engineering Toolkit (SET) can be used within a controlled laboratory environment to simulate a credential harvesting attack. The exercise illustrates how phishing websites can imitate legitimate login pages and capture submitted credentials, emphasizing the importance of user awareness and defensive security controls.

Environment

Item	Description
Operating System	arch Linux (main boot)
Tool Used	Social Engineering Toolkit (SET)
Purpose	Security Awareness and Defensive Training

Procedure

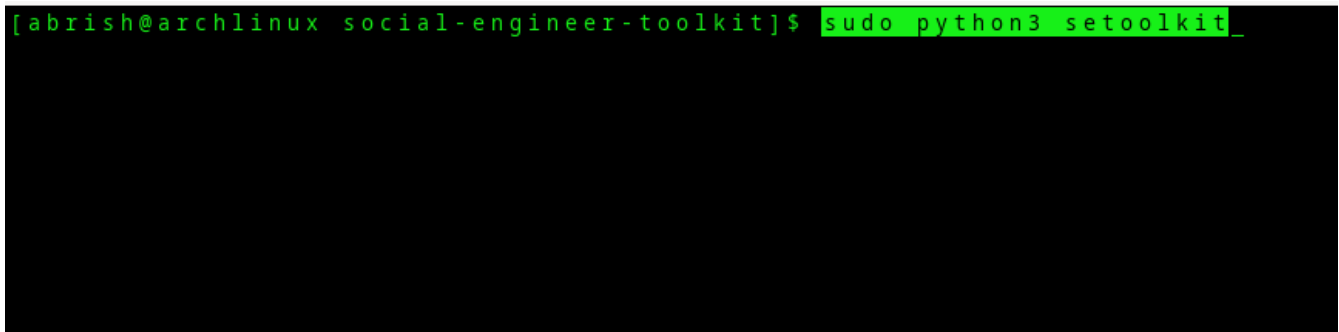
Step 1: Launch the Social Engineering Toolkit

The Social Engineering Toolkit was started from the terminal using administrative privileges.

Command

```
sudo python3 setoolkit
```

```
[abrish@archlinux social-engineer-toolkit]$ sudo python3 setoolkit_
```



Observation

SET loaded successfully and displayed the main menu containing the available attack vectors.

```
.M""bgd `7MM""YMM MMP""MM""YMM
,MI  "Y  MM  `7 P'  MM  `7
`MMb.  MM  d  MM
`YMMNq.  MmmMM  MM
.  `MM  MM  Y  ,  MM
Mb  dM  MM  ,M  MM
P"Ybmmd" .JMMmmmmMM .JMML.

[---] The Social-Engineer Toolkit (SET) [---]
[---] Created by: David Kennedy (ReL1K) [---]
[---] Version: 8.1.3 [---]
[---] Codename: 'Maverick' [---]
[---] Follow us on Twitter: @TrustedSec [---]
[---] Follow me on Twitter: @HackingDave [---]
[---] Homepage: https://www.trustedsec.com [---]
Welcome to the Social-Engineer Toolkit (SET).
The one stop shop for all of your SE needs.

The Social-Engineer Toolkit is a product of TrustedSec.

Visit: https://www.trustedsec.com

It's easy to update using the PenTesters Framework! (PTF)
Visit https://github.com/trustedsec/ptf to update all your tools!

Can't pickle local object <function show_banner.<locals>.pull_version at 0x7f72b1913530>
Select from the menu:

1) Social-Engineering Attacks
2) Penetration Testing (Fast-Track)
3) Third Party Modules
4) Update the Social-Engineer Toolkit
5) Update SET configuration
6) Help, Credits, and About

99) Exit the Social-Engineer Toolkit

set> _
```

Figure 1: SET Main Menu after launching the application.

Step 2: Select the Social Engineering Attack Menu

From the main menu, the **Social-Engineering Attacks** option was selected.

Menu Selection

1) Social-Engineering Attacks

Observation

The Social Engineering attack menu displayed several attack categories including website attacks, infectious media generation, payload creation, and other social engineering techniques.

```

  _____
 |  _   _  |
 | | | | | |
 | |_| | | |
 |  _  | | |
 | | | | | |
 |_____|_|_|

[---]      The Social-Engineer Toolkit (SET)      [---]
[---]      Created by: David Kennedy (ReL1K)      [---]
[---]              Version: 8.1.3
[---]              Codename: 'Maverick'
[---]      Follow us on Twitter: @TrustedSec      [---]
[---]      Follow me on Twitter: @HackingDave    [---]
[---]      Homepage: https://www.trustedsec.com   [---]
[---]      Welcome to the Social-Engineer Toolkit (SET).
[---]      The one stop shop for all of your SE needs.

  The Social-Engineer Toolkit is a product of TrustedSec.

  Visit: https://www.trustedsec.com

  It's easy to update using the PenTesters Framework! (PTF)
Visit https://github.com/trustedsec/ptf to update all your tools!

Can't pickle local object <function show_banner.<locals>.pull_version at 0x7f72b19137f0>
Select from the menu:

  1) Spear-Phishing Attack Vectors
  2) Website Attack Vectors
  3) Infectious Media Generator
  4) Create a Payload and Listener
  5) Mass Mailer Attack
  6) Arduino-Based Attack Vector
  7) Wireless Access Point Attack Vector
  8) QRCode Generator Attack Vector
  9) Powershell Attack Vectors
 10) Third Party Modules

 99) Return back to the main menu.

set> _
```

Figure 2: Social Engineering Attack Menu

Step 3: Select Website Attack Vectors

The Website Attack Vector module was selected to perform a web-based phishing simulation.

Menu Selection

2) Website Attack Vectors

Step 4: Select Credential Harvester Attack Method

The Credential Harvester module was selected.

Menu Selection

2 Website Attack Vectors and Credential Harvester Attack Method

Observation

SET prepared the Credential Harvester module and prompted for the desired web attack method.

```

The HTA Attack method will allow you to clone a site and perform PowerShell injection through HTA files which can be used for Windows-based PowerShell exploitation through the browser.

1) Java Applet Attack Method
2) Metasploit Browser Exploit Method
3) Credential Harvester Attack Method
4) Tabnabbing Attack Method
5) Web Jacking Attack Method
6) Multi-Attack Web Method
7) HTA Attack Method

99) Return to Main Menu

set:webattack>3

The first method will allow SET to import a list of pre-defined web applications that it can utilize within the attack.

The second method will completely clone a website of your choosing and allow you to utilize the attack vectors within the completely same web application you were attempting to clone.

The third method allows you to import your own website, note that you should only have an index.html when using the import website functionality.

1) Web Templates
2) Site Cloner
3) Custom Import

99) Return to Webattack Menu

set:webattack>_

```

Figure 4: Credential Harvester Menu and Website Attack Vector Menu.

Step 5: Select Site Cloner

The Site Cloner option was selected to create a copy of the target login page.

Menu Selection

2) Site Cloner (facebook.com)

Observation

SET requested the local IP address(192.168.1.4) and the {https://web.facebook.com/help/ipreporting/report/copyright?_rdc=1} of the Facebook.com website to clone.

```

set:webattack>2
[-] Credential harvester will allow you to utilize the clone capabilities within SET
[-] to harvest credentials or parameters from a website as well as place them into a report
-----
--- * IMPORTANT * READ THIS BEFORE ENTERING IN THE IP ADDRESS * IMPORTANT * ---

The way that this works is by cloning a site and looking for form fields to
rewrite. If the POST fields are not usual methods for posting forms this
could fail. If it does, you can always save the HTML, rewrite the forms to
be standard forms and use the "IMPORT" feature. Additionally, really
important:

If you are using an EXTERNAL IP ADDRESS, you need to place the EXTERNAL
IP address below, not your NAT address. Additionally, if you don't know
basic networking concepts, and you have a private IP address, you will
need to do port forwarding to your NAT IP address from your external IP
address. A browser doesn't know how to communicate with a private IP
address, so if you don't specify an external IP address if you are using
this from an external perspective, it will not work. This isn't a SET issue
this is how networking works.

set:webattack> IP address for the POST back in Harvester/Tabnabbing [192.168.1.4]:
[-] SET supports both HTTP and HTTPS
[-] Example: http://www.thisisafakesite.com
set:webattack> Enter the url to clone: https://web.facebook.com/help/ipreporting/report/copyright?_rdc=1

[*] Cloning the website: https://login.facebook.com/login.php
[*] This could take a little bit...

```

Step 6: Test the Cloned Login Page

The cloned webpage was opened from a web browser on the test machine.

Test credentials were entered into the login form.

Observation

The webpage closely resembled the legitimate login page and accepted the submitted test credentials.

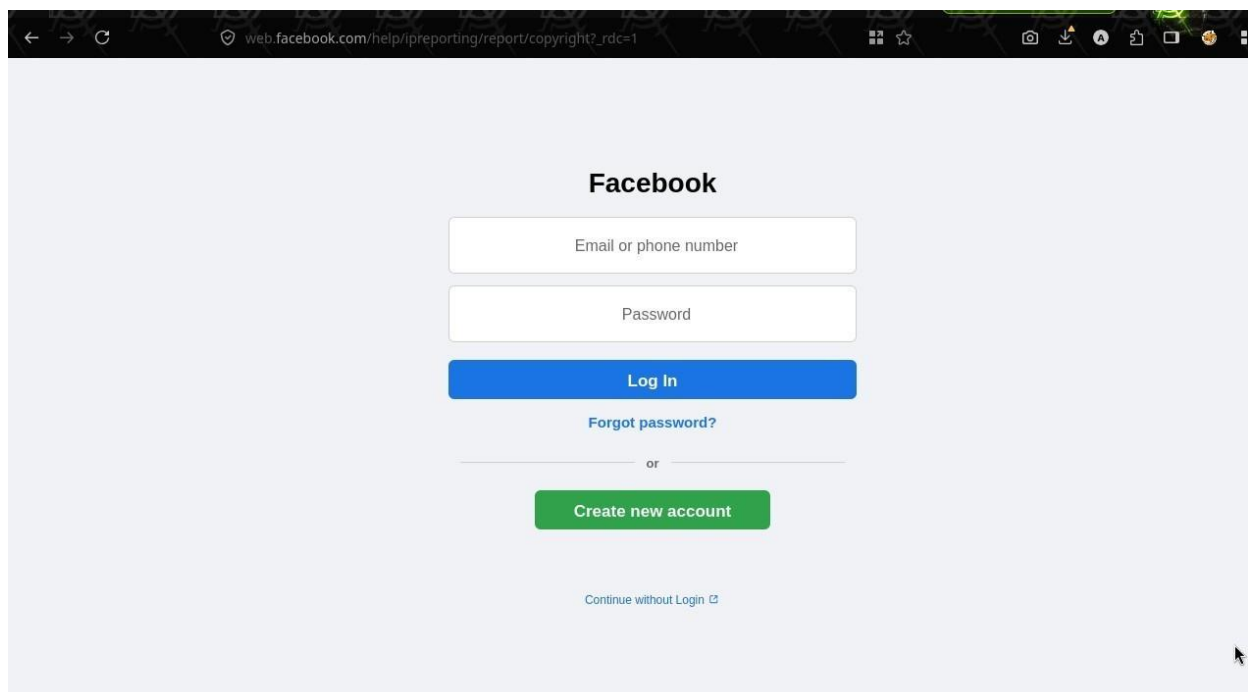


Figure 7: Cloned Login Page Displayed in the Browser.

Step 8: Verify Captured Credentials

After submitting the login form, the entered test credentials were displayed in the SET terminal.

Observation

The Credential Harvester successfully captured the submitted POST data and displayed the username and password entered during the simulation.

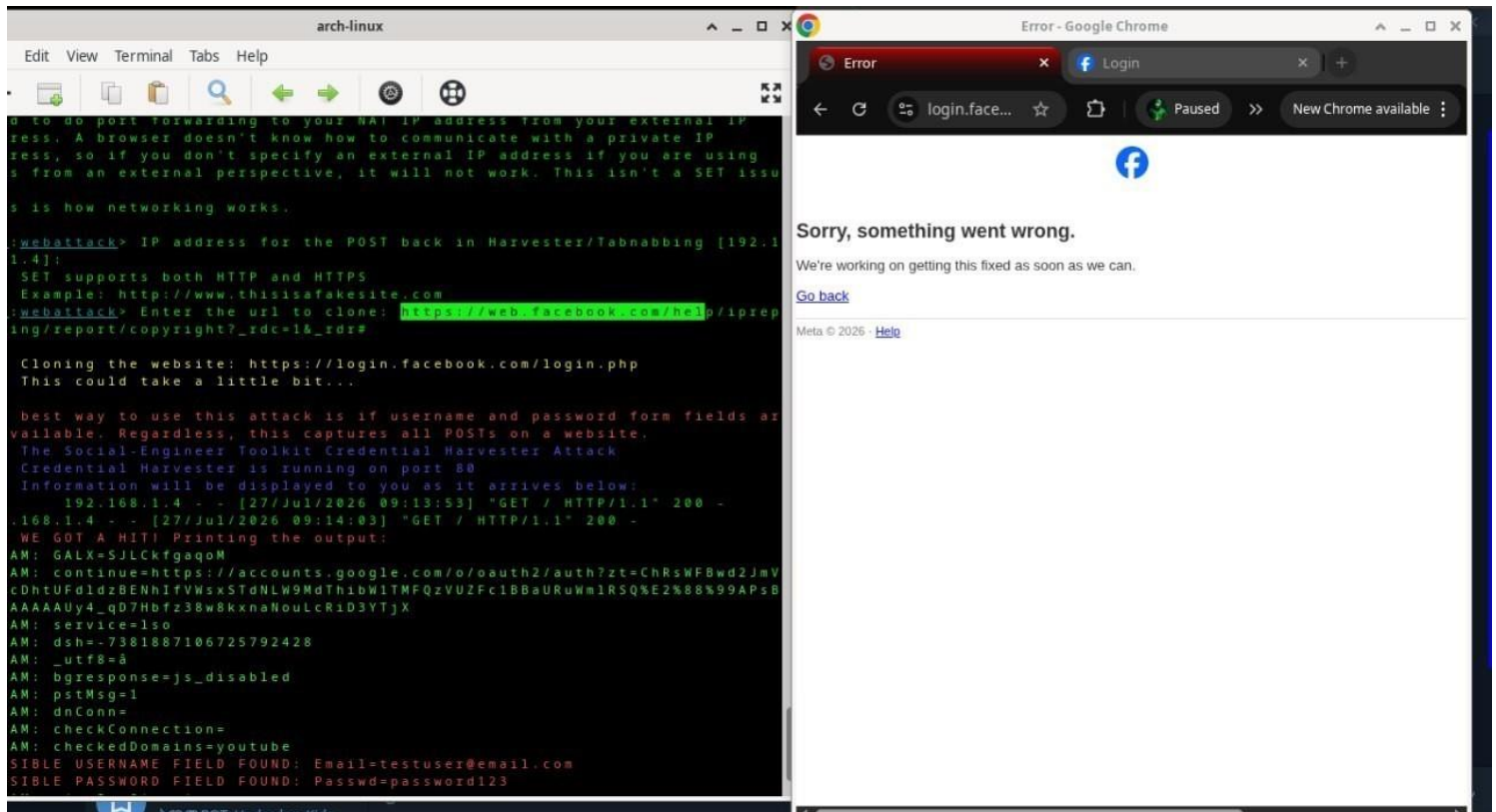


Figure 8: Credential Harvester Capturing Submitted Credentials.

- How difficult was it to create a convincing phishing page?
- What visual indicators might alert a user this is fake?
- How could you make this attack more convincing?

1. How difficult was it to create a convincing phishing page?

Creating a convincing phishing page was relatively easy using the Social Engineering Toolkit (SET). The toolkit automatically cloned the appearance of a legitimate website, requiring only basic configuration instead of advanced web development skills. This demonstrates how attackers can quickly create realistic phishing websites using publicly available tools, making phishing a significant cybersecurity threat.

2. What visual indicators might alert a user this is fake?

Several indicators can help users identify a phishing website:

- The URL is different from the legitimate domain or uses an IP address instead of the official website.
- Browser security warnings or an invalid SSL/TLS certificate may appear.
- Minor differences in branding, formatting, or page functionality.
- Password managers may not autofill credentials because the domain does not match the legitimate website.
- Unexpected requests to log in or verify account information.

Carefully checking these indicators before entering credentials can help users avoid phishing attacks.

3. How could you make this attack more convincing?

A phishing attack can appear more convincing by using a domain name that closely resembles the legitimate website, enabling HTTPS with a valid SSL certificate, accurately replicating the organization's branding, and sending personalized phishing emails that create a sense of urgency. These techniques increase the realism of phishing simulations and demonstrate why user awareness and careful verification are essential. Such techniques should only be used in authorized security testing and educational environments.

Analysis

This exercise demonstrated how phishing websites can mimic legitimate login pages to capture user credentials. It also showed that phishing attacks rely mainly on social engineering and user trust rather than technical vulnerabilities. The presence of a local IP address, missing trusted domain, and browser security warnings helped distinguish the fake site from the legitimate one, highlighting the importance of user awareness and verifying website authenticity before entering sensitive information.

Results

The phishing simulation was successfully completed within the isolated laboratory environment.

The following results were observed:

- The Social Engineering Toolkit launched successfully.
- The target website was cloned successfully.
- The cloned login page was hosted on the local laboratory network.
- Test credentials were submitted through the cloned webpage.
- The submitted credentials were successfully captured and displayed by the Credential Harvester module.
- The captured information demonstrated how attackers may collect sensitive information through phishing attacks.

Defensive Countermeasures

The following security practices can significantly reduce the effectiveness of credential harvesting attacks:

- Use password managers that automatically verify website domains.
- Enable Multi-Factor Authentication (MFA), preferably using phishing-resistant methods such as FIDO2 or WebAuthn.
- Conduct regular phishing awareness training for employees.
- Verify website URLs before entering usernames and passwords.
- Deploy secure email gateways with phishing detection capabilities.
- Monitor authentication logs for unusual login attempts.
- Encourage users to report suspicious emails and websites to the security team.

Conclusion

This exercise successfully demonstrated the use of the Social Engineering Toolkit (SET) to simulate a credential harvesting attack within a controlled laboratory environment. The exercise illustrated how attackers can create convincing phishing websites that closely resemble legitimate login pages and collect sensitive information from unsuspecting users. The results emphasize the importance of user awareness, URL verification, Multi-Factor Authentication, and ongoing security awareness training as effective defenses against phishing attacks.

